

Security audit

Framework references: OWASP ASVS, OWASP Top 10, OWASP API Security Top 10 and MASVS principles. No real-user data, credential validation, third-party attack, destructive action or disruptive load test was performed.

Security findings

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
SEC-001	Secrets	Credential material tracked in Git	Critical	Confirmed exposure; validity not tested	.env tracked; private-key blobs/non-placeholder key states; history	Cloud/data/payment/AI compromise and bills	Revoke/rotate, purge history, ignore, scan	Medium	CISO/DevOps	yes	Open
SEC-002	API authz	Cross-tenant S3 read/delete/list IDOR	High	Confirmed code path	storage controller missing ownership checks	KYC/chat/claim disclosure/deletion	Namespace ACL and tests	Medium	Backend	yes	Open
SEC-003	Trust/KYC	KYC always auto-approves	High	Confirmed	provider registry/mock provider/laC	Fraudulent verified badges/physical risk	Fail deployed mock; real/manual review	Medium	Trust/Backend	yes	Open
SEC-004	Edge	Public HTTP ALB bypasses CloudFront/WAF	High	High confidence	CDK public ALB, HTTP origin, raw output	Edge-control bypass	Private/restricted HTTPS authenticated origin	Medium	DevOps	yes	Open
SEC-005	Realtime	Arbitrary unauthenticated channel subscriptions	High	Confirmed design weakness	WS provider subscription path	Cross-user event leakage	Auth handshake; server-derived ACL	Medium	Backend	yes	Open
SEC-006	Safety	Cross-booking mass assignment/actor forgery	Medium	Confirmed	safety raw body/service	False emergency/audit records	Zod allowlist, ownership, server-owned fields/FK	Medium	Backend	before beta	Open
SEC-007	Abuse	Intended user rate limits are IP-keyed	Medium	Confirmed middleware order	limiter before route auth	CGNAT denial and cost-evasion	Authenticated subject key + IP edge limiter	Medium	Backend/SRE	before beta	Open
SEC-008	Session	Firebase bearer tokens in WS query strings	Medium	Confirmed	web/mobile WS URLs	Token leakage to logs/telemetry	Single-use WS tickets/no query token	Medium	Backend/Mobile	before beta	Open
SEC-009	Cache	Redis no TLS/auth/HA	Medium	Confirmed	CDK cache cluster	Confidentiality/availability risk	Replication group/TLS/auth	Medium	SRE	before real data	Open
SEC-010	Browser	Missing CSP/HSTS/frame/referer/permissions headers	Medium	Confirmed staging	curl -D - response	XSS/clickjacking impact amplification	CloudFront response-header policy	Low/Medium	DevOps/Web	before beta	Open

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
SEC-011	MASVS	Android backup may include persisted auth state	Medium	High confidence	AsyncStorage persistence + all owBackup	Session extraction via backup	Exclusions /secure storage/manifest test	Low/Medium	Mobile	before store	Open
SEC-012	Supply chain	98 production advisory instances across trees	High	Confirmed	root 13, API 24, mobile 61, infra 2	Known-vulnerability exposure	Reachability triage/upgrades/SBOM gate	Medium/High	Security	yes	Open
SEC-013	Privacy logs	Mobile logs speech results/partial; server logs identifiers	Medium	Confirmed	voice and notification logging	PII exposure in device/cloud logs	Remove/redact; production log policy	Low	Mobile/SRE	before real data	Open

Detailed high-severity records

SEC-001 - credential material tracked in Git

- * CVSS estimate: 9.1; CWE-798, CWE-312.
- * Affected: tracked .env, .env.staging, server/.env, mobile/.env; history from 9069c47.
- * Safe reproduction: git ls-files plus a redacted parser that reports key name, non-empty state and length only.
- * Preconditions: repository/history access.
- * Potential impact: Firebase/Vertex impersonation, database/payment/Google/AI access and denial-of-wallet. Exact scope depends on key validity and provider restrictions.
- * Likelihood: high; exposure is certain, validity deliberately untested.
- * Fix: rotate first, then remove files/history; Secrets Manager/EAS; pre-commit/CI scanning.
- * Regression: CI fails if real env/private-key/token patterns are tracked.
- * Exploitation: not attempted.

SEC-002 - cross-tenant storage IDOR

- * CVSS estimate: 8.1; CWE-862, CWE-639; OWASP API1 Broken Object Level Authorization.
- * Affected: presign download, delete and list methods in storage.controller.ts.
- * Evidence: upload calls assertKeyOwnedByUser; these methods validate only input shape/bucket and call provider.
- * Safe reproduction: unit mock attacker user plus victim-scoped key/prefix; assert provider is called.
- * Preconditions: valid account and discoverable/guessed object key.
- * Impact: disclosure/deletion/enumeration of verification, claim, chat or upload objects.
- * Fix/test: force caller namespace, explicit admin authorization, opaque object mapping; attacker returns 403 and provider is never called.
- * Exploitation: code-level confirmed, staging exploit not attempted.

SEC-003 - mock KYC auto-approval

- * CVSS estimate: 8.1; CWE-345, CWE-602.

- * Evidence: non-mock branch maps to mock provider; mock returns approved; IaC injects mock.
- * Preconditions: authenticated submission.
- * Impact: fraudulent providers gain trust badge and marketplace access.
- * Fix/test: startup failure for mock in deployed tiers, pending state until manual/regulated review, audited dual control.
- * Exploitation: implementation confirmed; no live submission.

SEC-004 - edge bypass

- * CVSS estimate: 7.5; CWE-284, CWE-319.
- * Safe reproduction: CDK assertion, not a direct-origin probe.
- * Fix/test: internal/VPC origin or CloudFront prefix restriction plus rotating origin secret; HTTPS; direct origin unreachable/403.

SEC-005 - realtime authorization

- * CVSS estimate: 7.5; CWE-862, CWE-639.
- * Safe reproduction: isolated WS unit test subscribing attacker to synthetic victim channel.
- * Fix/test: mandatory authenticated upgrade; server derives allowed user/conversation channels; anonymous/cross-user subscription rejected.

Missing evidence

Authenticated staging role tests, mobile binary analysis, cloud IAM/deployed security groups, WAF logs, secret-provider logs, penetration testing, SAST/SCA reachability, backup exposure and incident drills were unavailable. Absence of confirmed exploitation is not proof of safety.